Global Regulations & Standards at a Glance

Regulators in every major market now expect medical devices to be secure, and standards describe how to get there. Use this map to recognize the names, see which are binding, and know who to ask. You don't need to memorize it.

CURRENT AS OF OCTOBER 2026

This area changes often. Statuses and dates were checked in October 2026 and will move; your regulatory team tracks the current versions for your products. **Training material, not legal or regulatory advice:** your regulatory team owns interpretation.

How the layers fit

LAW AND REGULATION
Binding. Says what must be achieved.
US Section 524B · QMSR
EU MDR and IVDR

GUIDANCE
Regulator's current thinking. Not binding, but it is what reviewers look for.
FDA premarket and postmarket guidance · MDCG 2019-16

STANDARDS
Consensus on how. Voluntary; regulators recognize many.
IEC 81001-5-1 · AAMI SW96 · ISO 14971 · ISO 13485

YOUR QUALITY SYSTEM
Makes it daily work.
Design controls · risk management · supplier controls · complaints and CAPA

United States · FDA

Section 524B, FD&C Act — LAW — Since March 2023

Every cyber device submission must include a plan to monitor and address postmarket vulnerabilities, with coordinated vulnerability disclosure (CVD); processes that give reasonable assurance of security, including regular updates and fast patches for critical problems; and a software bill of materials (SBOM). Since October 2023, submissions missing this can be refused.

Premarket cybersecurity guidance — GUIDANCE

2023; updated 2025; reissued Feb 2026

A Secure Product Development Framework (SPDF) inside the quality system; threat modeling and security risk management linked to safety risk; architecture views; security controls; testing; an SBOM with support status; labeling; a cybersecurity management plan.

Postmarket cybersecurity guidance — GUIDANCE

Dec 2016; still current

Monitor vulnerabilities and judge whether the risk of patient harm is **controlled** (fix in routine updates) or **uncontrolled** (fix promptly; generally reportable, with reporting relief when customers are told quickly, the fix is fast, and the manufacturer takes part in an information sharing and analysis organization).

QMSR (Quality Management System Regulation)

REGULATION — Effective Feb 2026

Incorporates ISO 13485. No cyber clause, but FDA maps security work onto design, risk management, supplier controls and CAPA.

AI-enabled device software guidance — DRAFT — Jan 2025

For AI devices, covers AI-specific threats such as poisoned training data and manipulated inputs.

Cyber device (Section 524B): includes software, can connect to the internet, and could be vulnerable to cyber threats. FDA reads this broadly: an indirect path through a phone, transmitter, hospital network or service port can count.

European Union

MDR and IVDR: general safety and performance requirements (GSPRs)

REGULATION — In force

Software developed to the state of the art, with risk management that includes information security; minimum IT security requirements stated in the instructions for use; protection, as far as possible, against unauthorized access.

MDCG 2019-16 — GUIDANCE — Rev.1, July 2020

How to meet the GSPRs: secure design, operating environment, testing, postmarket vigilance, and joint responsibility with the hospitals that run devices.

Cyber Resilience Act (CRA) — REGULATION

Reporting Sep 2026; full Dec 2027

Excludes MDR and IVDR devices, but reaches suppliers' software components, gateways and non-medical accessories sold in the EU.

NIS2 Directive — DIRECTIVE — National laws from Oct 2024

About the company, not the product: organizational cyber risk management and incident reporting for manufacturers above size thresholds.

AI Act — REGULATION — Device AI duties moved to 2028

For AI in devices: accuracy, robustness and cybersecurity, including resistance to poisoned data and manipulated inputs.

MDR and IVDR revision — PROPOSAL — Under negotiation

Would make cybersecurity explicit in the GSPRs and add reporting of actively exploited vulnerabilities, in line with the CRA.

Other major markets and IMDRF

Canada · Health Canada GUIDANCE 2019
Cyber evidence in higher-class licence applications: risk analysis, a bill of materials, testing, labeling, a traceability matrix and a plan for monitoring new threats.

United Kingdom · MHRA DRAFT 2026 amendments
Draft amendments would align UK requirements with the EU GSPRs; MHRA runs a cybersecurity workstream for software and AI.

Australia · TGA REGULATION GUIDANCE Guidance 2022
Manage cyber risk across the lifecycle and monitor new vulnerabilities, to meet the Essential Principles.

Japan · MHLW/PMDA REGULATION Mandatory since Apr 2024
Cyber risk management under the Essential Principles; conformance to JIS T 81001-5-1 (identical to IEC 81001-5-1) is the accepted route.

China · NMPA GUIDANCE 2022 revision
Cybersecurity documentation for registration, update management, a component list, vulnerability assessment and testing.

IMDRF · International Medical Device Regulators Forum
SHARED PRINCIPLES 2020; 2023
Its 2020 cybersecurity principles are the baseline (lifecycle, shared responsibility, coordinated disclosure, SBOMs, legacy devices); 2023 documents add detail on legacy devices and SBOMs. Not law, but national rules borrow from it.

Also moving: Brazil (a non-binding guide), Singapore (a voluntary cybersecurity label for devices), South Korea (a cybersecurity review guideline). One market's approval doesn't cover another, but good evidence travels.

The good news: expectations converge

Almost every regulator asks for: security built into design, inside the quality system · security risk linked to safety risk · security testing · an SBOM · a plan for vulnerabilities after release · clear security information for customers.

Standards and frameworks · most are voluntary, but regulators recognize many

ISO 13485 REQUIRED in the US, via the QMSR
Quality management system standard; security processes live inside it. Used by: Quality; every team

ISO 14971 VOLUNTARY
Safety risk management; its scope includes data and systems security. Used by: Risk, quality, clinical

ANSI/AAMI SW96 VOLUNTARY FDA-recognized
Security risk management run alongside ISO 14971 (2023). Used by: Product security, risk

AAMI TIR57, TIR97 VOLUNTARY
Security risk reports; SW96 has largely replaced TIR57. TIR97 covers postmarket. Used by: Product security, PSIRT

IEC 81001-5-1 VOLUNTARY FDA-recognized; Japan's route
Security activities across the health software lifecycle, from design to testing and updates (2021). Used by: Engineering, product security

IEC 62443-4-1, 4-2 VOLUNTARY supports device claims
Industrial standards for secure development and component security requirements. Used by: Engineering, suppliers

ISO/IEC 29147, 30111 VOLUNTARY referenced by FDA
Vulnerability disclosure (receiving, publishing) and vulnerability handling (investigating, fixing). Used by: PSIRT

SPDX, CycloneDX An SBOM is REQUIRED in the US; the format is your choice
Machine-readable SBOM formats that tools check against vulnerability databases. Used by: Engineering build tools

CVSS, VEX VOLUNTARY
CVSS scores severity (FDA qualified a MITRE rubric for clinical use); VEX says whether a known flaw affects a product. Used by: PSIRT; customers read VEX

MDS2 form CUSTOMER not a regulation
Manufacturer Disclosure Statement for Medical Device Security; hospitals compare devices with it. Used by: Hospital buyers; sales

HSCC JSP2, MC2 VOLUNTARY
Health Sector Coordinating Council: Joint Security Plan (secure-by-design framework) and Model Contract (who owns which cyber duties). Used by: Program leads; sales, procurement

NIST SSDF VOLUNTARY
Secure Software Development Framework: secure development practices. Used by: Software engineering

CISA Secure by Design VOLUNTARY
Principles and a pledge for software vendors generally; not device law. Used by: Software vendors

ISAOs (Health-ISAC) VOLUNTARY eases FDA reporting terms
Information Sharing and Analysis Organizations share threat information. Used by: PSIRT

What this means for a product team

- Build one program on recognized standards; the same evidence feeds FDA, EU and other submissions.
- Security deliverables are schedule items: a US cyber device submission without them can be refused.
- Know what applies to what: FDA rules and the MDR/IVDR cover the product; NIS2 the company; the CRA mostly suppliers; the AI Act AI features.
- Ask regulatory which markets you sell in and which standards you declare. Current as of October 2026; not legal or regulatory advice.